

JUNIO 2026

THE BRIDGE
BOOTCAMPS

A series of white, wavy, horizontal lines of varying thicknesses that create a sense of movement and depth across the middle of the page.

MARCO DE SEGURIDAD DEL PROYECTO - SSDLC



Versión	Fecha	Estado	Clasificación
1.0	Junio 2026	Aprobado	Interno

01 Propósito y alcance

Este documento establece el marco de seguridad que rige el desarrollo del proyecto. Define los principios, las actividades, las responsabilidades y los criterios de aceptación que el equipo de ciberseguridad aplica a lo largo de todo el ciclo de vida del software. Es de aplicación a todos los equipos participantes y actúa como referencia metodológica permanente, no como registro de actividades.

La metodología que lo sustenta es el SSDLC – Secure Software Development Lifecycle. Su principio central es incorporar la seguridad en cada fase del desarrollo, no al final.

Un fallo detectado en producción cuesta entre 30 y 100 veces más de corregir que uno detectado en diseño.

Equipos a los que aplica

CIBERSEGURIDAD**FULL STACK****DATA SCIENCE****MARKETING DIGITAL**

02 Principios de seguridad



Mínimo privilegio

Cada componente accede únicamente a lo que necesita para su función.



Defensa en profundidad

Múltiples capas de protección. El fallo de una no compromete el conjunto.



Fail-safe defaults

El comportamiento por defecto es denegar. Los permisos se conceden explícitamente.



Separación de responsabilidades

Ningún componente tiene control completo sobre una operación crítica.



Superficie mínima

Todo lo que no es necesario no existe: endpoints, servicios, dependencias.



Seguridad por diseño

Las decisiones de seguridad se toman en diseño. Un fallo de diseño no se parchea.

03 Estructura por etapas

Etapas 1 - Conocer el terreno

Fases de requisitos y diseño del SSDLC

Informe OSINT - Presencia digital, infraestructura expuesta y vectores de ataque desde fuentes abiertas.

Análisis MAGERIT - Identificación y valoración de activos, amenazas y riesgo residual. Resultado: mapa de riesgos priorizado.

Threat Model ATT&CK - Traducción de hallazgos MAGERIT a técnicas de ataque concretas con controles de mitigación.

Qué se necesita de cada equipo: descripción de activos de información, datos que maneja, accesos, servicios externos y impacto ante compromiso. Marketing Digital aporta además las plataformas de terceros previstas y el tipo de datos de usuarios a recoger.

Etapa 2 - Construir con seguridad

Fases de implementación y pruebas del SSDLC

Análisis OWASP Top 10 - Evaluación frente a las diez categorías de riesgo críticas en aplicaciones web.

Informe de hardening - CIS Benchmarks sobre servidor y servicios: cabeceras HTTP, configuración y parámetros de sistema.

Marco Normativo - Requisitos de privacidad, cookies, consentimiento e integraciones externas. Afecta especialmente a Marketing Digital.

Qué se necesita de cada equipo: acceso de lectura a repositorios, notificación de despliegues en staging y disponibilidad para revisar hallazgos críticos. Marketing Digital aporta el inventario de scripts de terceros y píxeles de seguimiento.

Etapa 3 - Estar preparados para lo inesperado

Fases de despliegue y mantenimiento del SSDLC

Playbook de incidentes - Procedimientos de respuesta para escenarios de ataque reales sobre la aplicación.

Sistema de backup - Estrategia de copia: frecuencia, retención, verificación de integridad y coste estimado.

Reglas SIEM - Firmas de detección para identificar patrones de ataque reales en tiempo real.

Procedimiento DFIR - Respuesta forense: preservación de evidencias, análisis de causa raíz y documentación.

DBCP / DRP - RTO y RPO por componente crítico y procedimientos de activación del plan de continuidad.

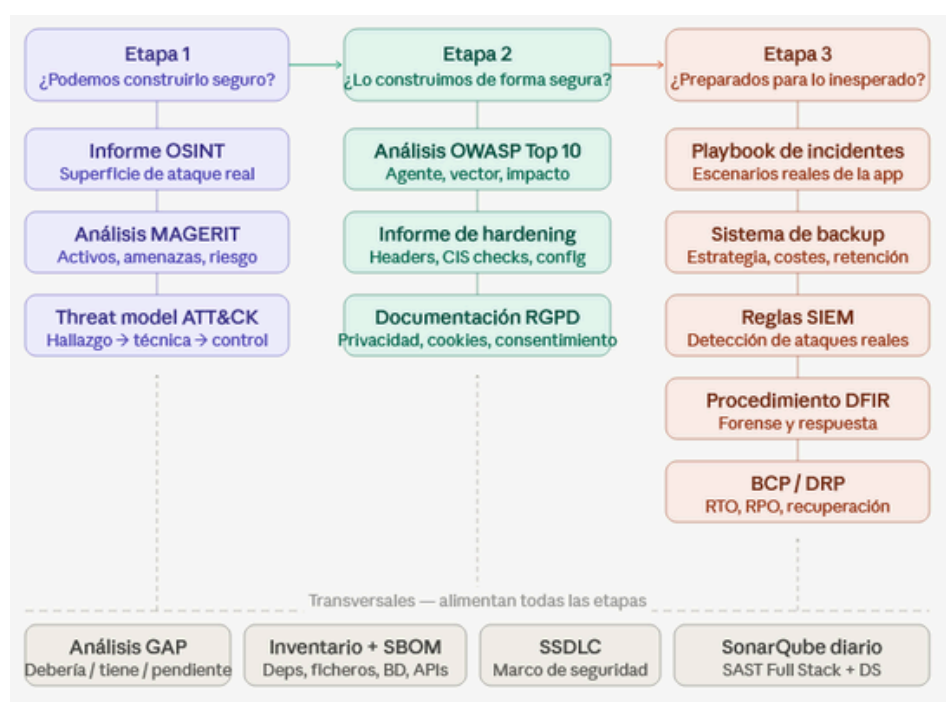
Qué se necesita de cada equipo: descripción de flujos críticos, estado del logging, comportamiento ante indisponibilidad de servicios externos. Marketing Digital define qué ocurre con campañas activas ante caída del sistema.

Actividades transversales

SonarQube diario - Análisis SAST automatizado sobre repositorios de Full Stack y Data Science. Informe diario por vertical con hallazgos clasificados por severidad.

Inventario activos + SBOM - Registro de todos los componentes de software: librerías, versiones y dependencias transitivas. Se actualiza con cada cambio relevante.

Marco SSDLC - Este documento. Referencia metodológica que orienta todas las decisiones de seguridad del proyecto durante las tres etapas.



04 Gestión de hallazgos

Todo hallazgo identificado por el equipo de ciberseguridad se clasifica según su severidad y se gestiona conforme a los siguientes criterios.

Los hallazgos de severidad Crítica y Blocker requieren comunicación inmediata al equipo responsable y resolución antes de continuar el desarrollo sobre el componente afectado. Los hallazgos de severidad Alta deben resolverse dentro del sprint en curso. Los hallazgos de severidad Media se planifican para el siguiente sprint. Los hallazgos de severidad Baja e Informativa se documentan y se atienden según disponibilidad sin bloquear el desarrollo.

Cuando un equipo considere que un hallazgo es un falso positivo o que no aplica en su contexto, lo comunica al equipo de ciberseguridad con una justificación. El equipo de ciber lo revisa y determina si se acepta la excepción o se mantiene el hallazgo. Toda excepción aceptada queda documentada.

CRÍTICA/BLOCKER

resolución inmediata, bloquea desarrollo

ALTA

resolución en el sprint en curso

MEDIA

planificar para el siguiente sprint

BAJA

atender según disponibilidad, no bloquea

INFORMATIVA

documentar, sin urgencia

05 Criterios de aceptación

Un componente es aceptable cuando cumple todas las condiciones siguientes:

- ✓ Sin hallazgos Críticos o Blocker sin resolver en el análisis estático.
- ✓ Sin dependencias con CVSS ≥ 9.0 sin justificación documentada.
- ✓ Hallazgos de severidad Alta con plan de resolución acordado.
- ✓ Sin credenciales ni secretos expuestos en el repositorio.

El incumplimiento de cualquiera de estas condiciones en el momento del despliegue bloquea la puesta en producción hasta su resolución.

06 Herramientas de referencia

Herramienta	Tipo	Etapas	Verticales
whois	Reconocimiento	1	Transversal
dig	Reconocimiento	1	Transversal
MAGERIT	Análisis de riesgos	1	Transversal

Herramienta	Tipo	Etapas	Verticales
TheHarvester	Reconocimiento	1	Transversal
MITRE ATT&CK	Threat modeling	1	Transversal
Spiderfoot	Reconocimiento	1	Transversal
Shodan	Reconocimiento	1	Transversal
Docker	Contenedores	Transversal	Transversal
SonarQube	SAST	Transversal	Full Stack + DS
Semgrep	SAST	Transversal	Full Stack + DS
pip-audit	SCA dependencias	Transversal	DS
npm audit	SCA dependencias	Transversal	Full Stack
grep	Búsqueda de secretos	Transversal	Full Stack + DS
GitHub Pages	Despliegue dashboard	Transversal	Ciber
Chart.js	Visualización	Transversal	Ciber

